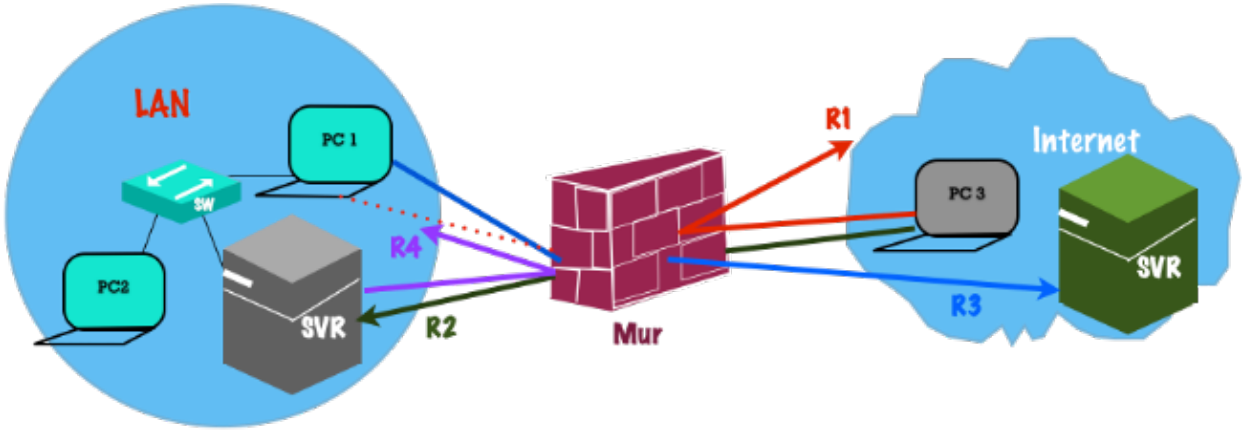
Chapitre 5

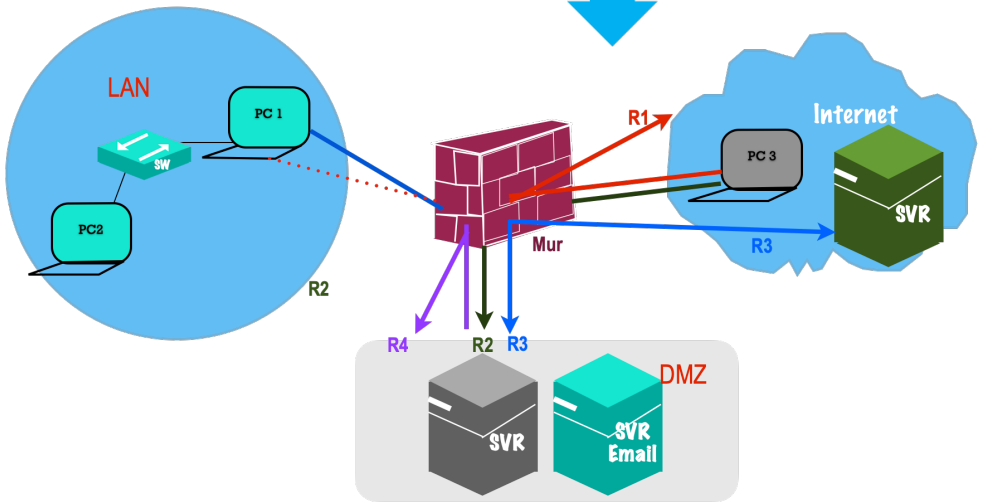
Les listes de contrôle d'accès (ACL)

DMZ pour les serveurs

- Doit on autoriser n'importe quel ordinateur à accéder à n'importe quelle ressource matérielle ou logicielle?



Serveurs isolés



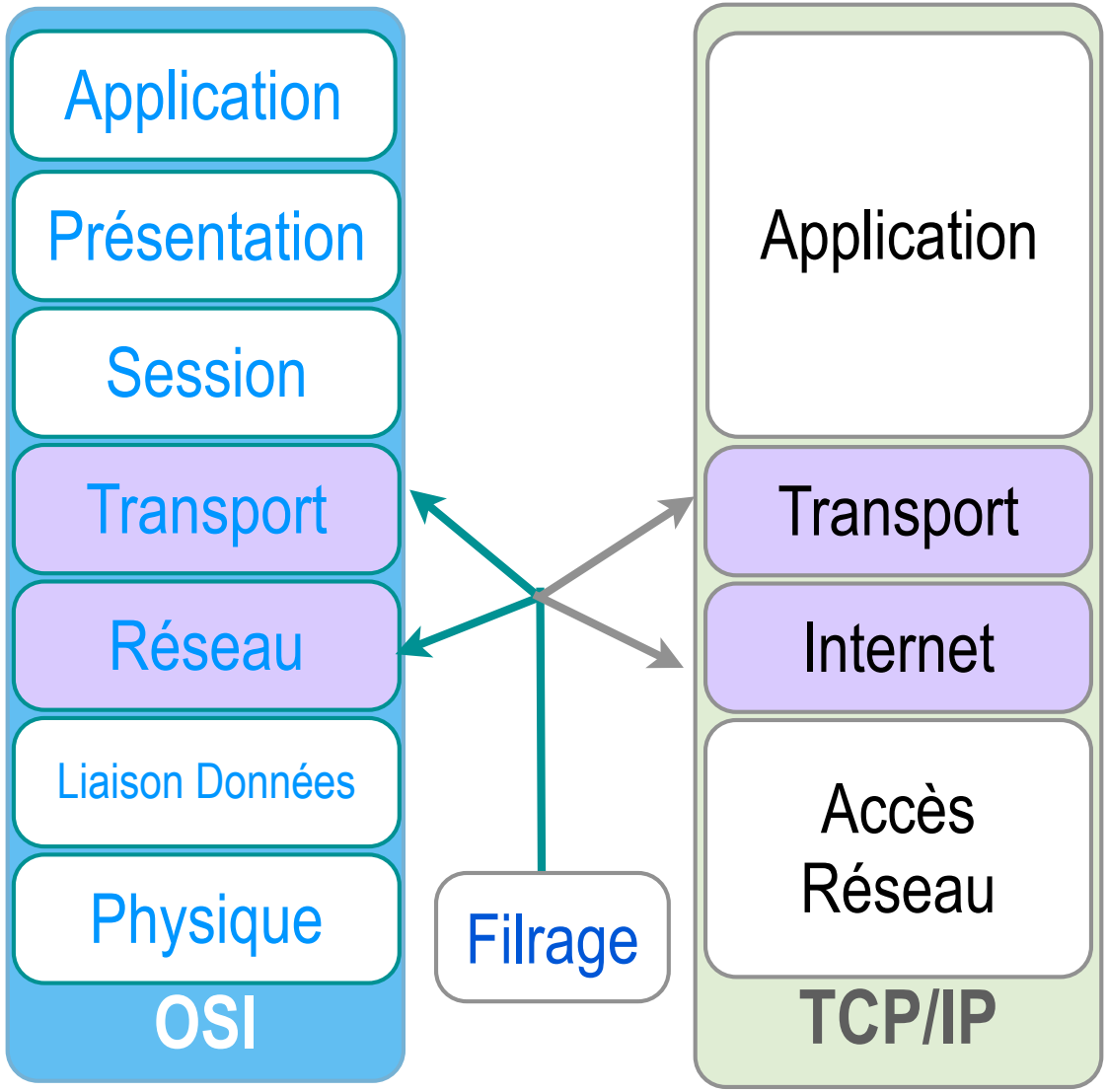
- R1: Internet vers le LAN: refusée
- R2: Internet vers le LAN: autorisée
- R3: LAN vers Internet: autorisée
- R4: LAN vers Internet: refusée

Présentation

- Sur **un routeur Cisco**, on peut configurer un **pare-feu** simple, qui assurera les fonctions de base du filtrage du trafic à l'aide de **listes de contrôle d'accès** ou **ACL** (Access Control Lists)
- Une ACL est un ensemble séquentiel d'instructions d'**autorisation** ou de **refus** qui s'appliquent aux adresses IP, aux protocoles ou au ports
- Une ACL est une série de commandes IOS qui déterminent si un routeur achemine ou abandonne les paquets en fonction des informations contenues dans l'en-tête du paquet
- On distingue **les ACL standards** et **les ACL étendues** sur un routeur Cisco pour une solution de sécurité

ACL sur les couches

- Un **routeur** peut filtrer les paquets au niveau des couches 3 et 4 de OSI ou 2 et 3 de TCP/IPU.
- **Les critères** de filtrage sont:
  - L'adresse IP source
  - L'adresse IP de destination
  - Le protocole
  - Les numéros de Port source TCP/UDP
  - Les numéros de Port de destination TCP/UDP
- Les règles sont définies à l'aide des **ACL**



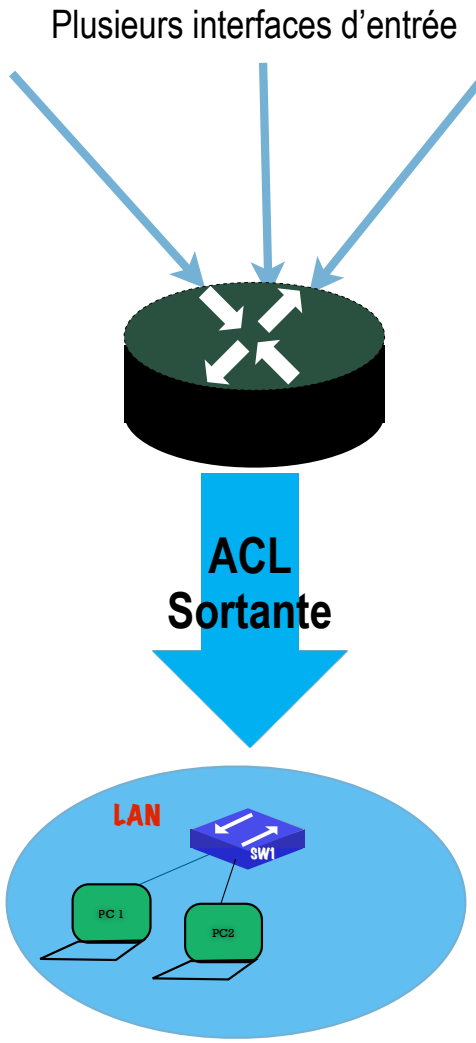
ACL entrantes et sortantes

- Les ACL sont configurées pour s'appliquer au trafic entrant ou sortant.
  - **ACL entrantes**
    - Filtre les paquets entrant dans une interface avant qu'ils ne soient acheminés
    - Les paquets entrants sont traités avant d'être routés vers l'interface de sortie
    - Les ACL entrantes sont idéales pour filtrer les paquets lorsque le réseau est relié à une interface d'entrée qui sera la seule source des paquets devant être inspectés.



ACL entrantes et sortantes

- **ACL sortante**
  - Filtre les paquets après qu'ils ont été routés quelque soit l'interface de sortie.
  - Les paquets entrants sont traités par le biais de l'ACL sortante.
  - Les ACL sortantes sont efficaces lorsqu'un même filtre est appliqué aux paquets provenant de plusieurs interfaces d'entrée



ACL standards / ACL étendues

- **ACL standards:** filtrent le trafic en fonction de l'adresses IPv4 source uniquement.

- **ACL étendues:** filtrent le trafic en fonction de:
  - des adresses IP source et de destination
  - des ports TCP et UDP sources et de destination
  - le type ou le numéro de protocole (exemple: IP, ICMP, UDP, TCP etc.)

ACL standards / ACL étendues

- ACL standards ou étendues peuvent être identifiées par un **numéro** ou par un **nom.**

- **ACL numérotées:** attribuent un numéro en fonction du protocole à filtrer
  - ACL IP standards: plage de 1 à 99 et de 1300 à 1399
  - ACL IP étendues: plage de 100 à 199 et de 2000 à 2699

- **ACL nommées**: attribuent un nom à la liste en fonction des paramètres
  - Le nom est composé de caractères alphanumériques, pas d'espace ni de signe de ponctuation
  - Il est conseillé d'écrire les noms en majuscule.

Le masque générique

- Le masque générique est une chaîne de 32 bits utilisés par le routeur pour déterminer quels bits de l'adresse examinés afin d'établir une correspondance.
- Le masque générique peut être une suite quelconque de 1 et de 0 en fonction du filtrage que l'on veut opérer sur des adresses IP
  - Un bit à 0 est à vérifier
  - Un bit à 1 est à ignorer
- Exemple:
  - l'adresse IP de référence (binaire): 00001010. 00000000. 00000001.00000000
  - Masque générique (binaire): 00000000. 00000000. 00000000.11111111
  - Le dernier octet est ignoré dans la vérification
  - On a toutes les adresses de 10.0.1.0 à 10.0.1.255 dans la plage
- Une méthode rapide pour calculer le masque générique consiste à soustraire le masque de sous-réseau de 255.255.255.255.

Le masque générique

- **Quelques exemples de masques générique**
  - l'adresse IP=192.168.1.1 : 11000000. 10101000. 00000001.00000001
  - MG = 0 . 0 . 0 . 0 : 00000000. 00000000. 00000000.00000000
    - Tous les bits sont à vérifier
    - On a l'adresse 192.168.1.1
  - l'adresse IP=192.168.16.0 : 11000000. 10101000. 0001**0000.00000000**
  - MG = 0 . 0 .15.255 : 00000000. 00000000. 0000**1111.11111111**
    - Les 20 premiers bits sont à vérifier
    - Plage de 192.168.16.0 11000000. 10101000. 0001**0000.00000000** à
    - 192.168.31.255 11000000. 10101000. 0001**1111.11111111**
  - l'adresse IP=192.168.1.0 : 11000000. 10101000.00000001.00000000
  - MG = 0 . 0 .254. 0 : 00000000. 00000000.11111110.00000000
  - On tous les réseaux impairs sur le réseau principale 192.168.0.0

Le masque générique

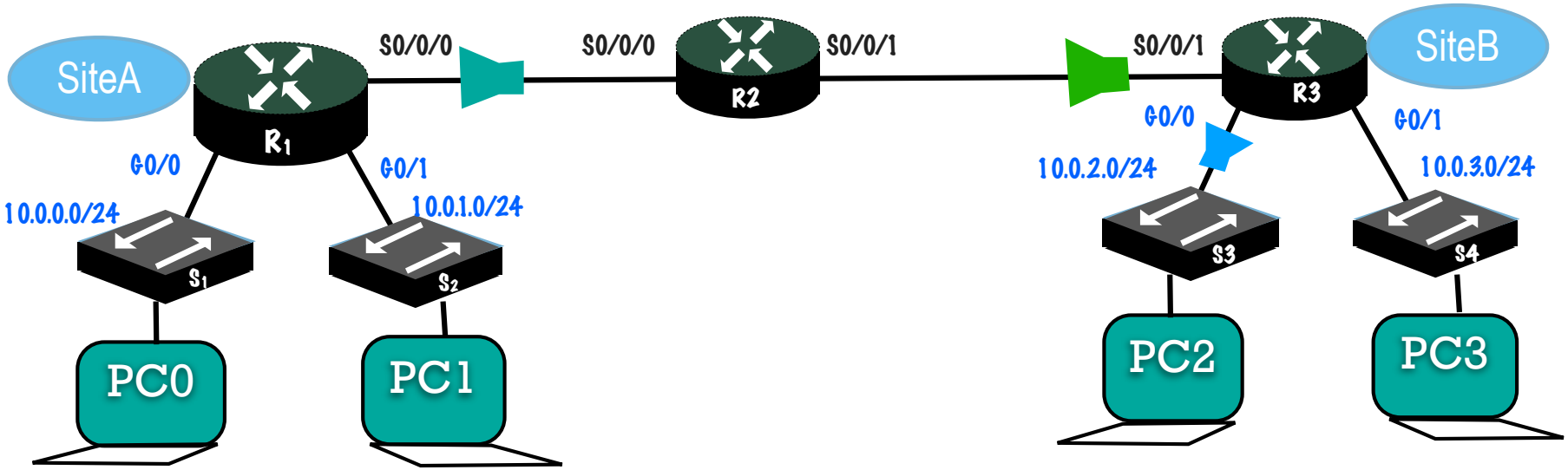
- Le mot clé **host** dans un ACL remplace le masque 0.0.0.0. Ce masque indique que tous les bits de l'adresse IPv4 doivent correspondre ou qu'un seul hôte est conforme.
  - 192.168.10.10 0.0.0.0 = host 192.168.10.10.
- Le mot-clé **any** remplace l'adresse IP et le masque 255.255.255.255. Ce masque indique qu'il convient d'ignorer l'intégralité de l'adresse IPv4 ou d'accepter n'importe quelle adresse.
  - 255.255.255.255 = any

Position des ACL

- La liste de contrôle d'accès doit être placée là où elle aura le plus grand impact sur les performances
  - la règle générale est de placer les **ACL étendues** aussi près que possible de la **source**
    - Ainsi le trafic indésirable est refusé près du réseau source et ne traverse pas l'infrastructure réseau.
  - Et les **ACL standards** aussi près que possible de la **destination**
    - Ce qui empêche efficacement ce trafic d'accéder à tous les autres réseaux via l'interface à laquelle la liste est appliquée.

Position des ACL standards

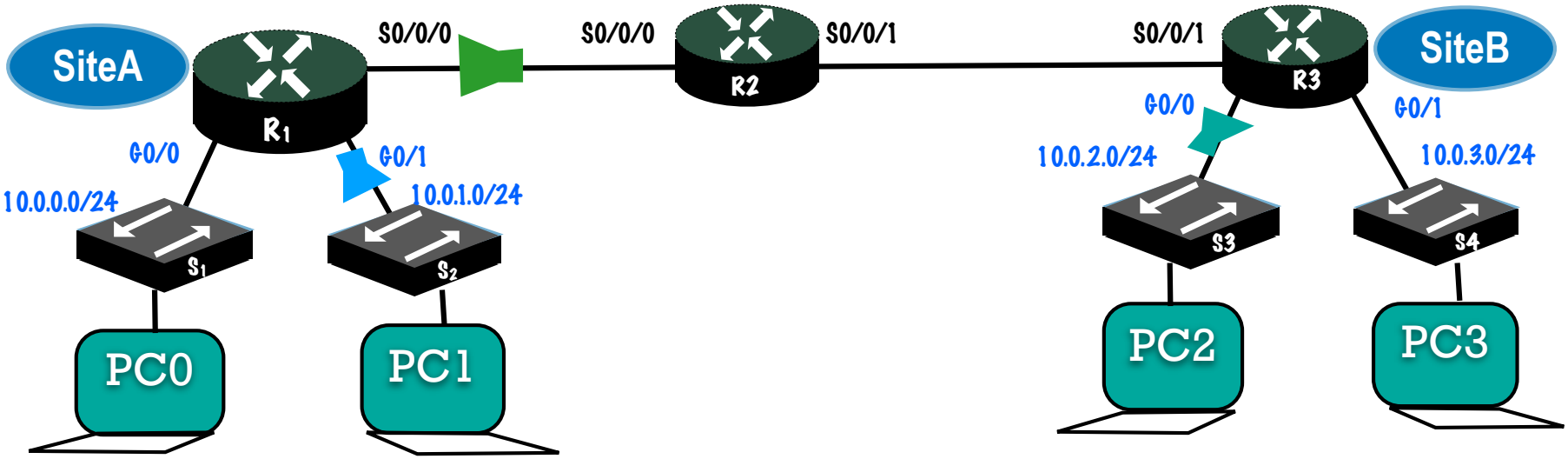
- L'administrateur veux empêcher le trafic du réseau 10.0.0.0 (site A) d'accéder au réseau 10.0.2.0 (site B)



- L'ACL sur S0/0/0 de R1 empêche le trafic du réseau 10.0.0.0 d'accéder à tout réseau accessible via S0/0/0 de R1
- L'ACL sur S0/0/1 de R3 empêche le trafic du réseau 10.0.0.0 d'accéder au 10.0.2.0 et tous les réseaux accessibles par R3 comme le 10.0.3.0
- L'ACL sur G0/0 de R3 filtre les paquet provenant de 10.0.0.0 à destination de 10.0.2.0 et n'affecte pas les autres réseaux (**meilleure solution**)

Position des ACL étendues

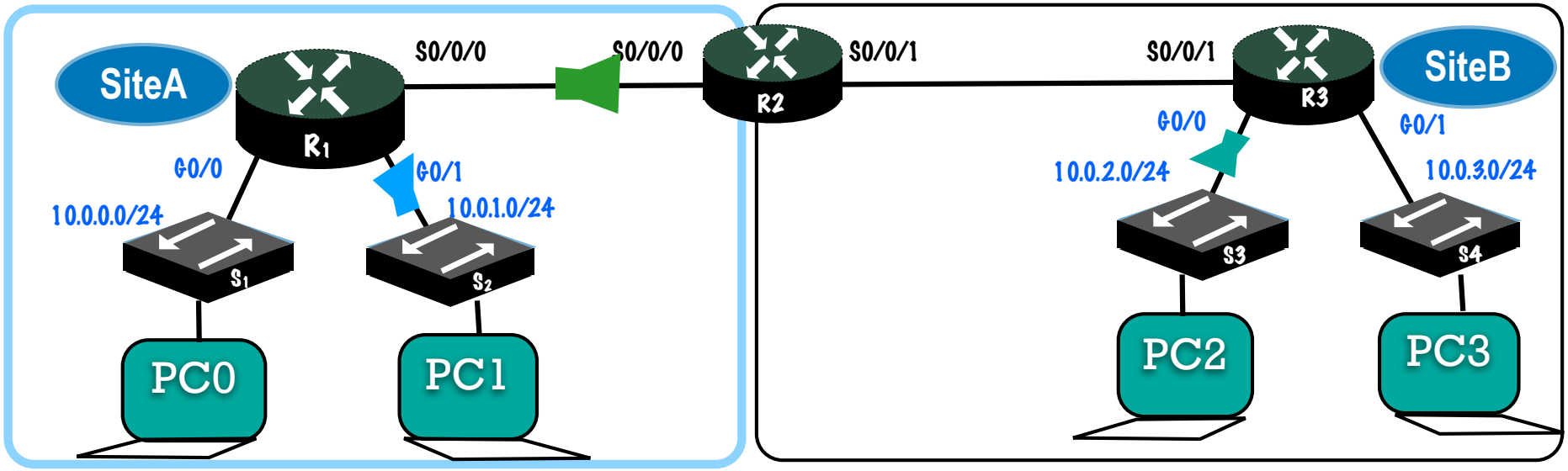
- L'administrateur souhaite refuser le trafic Telnet et FTP provenant du réseau 10.0.1.0/24 vers le réseau 10.0.2.0/24 du site B



- L'ACL étendue sur R3 bloquant le trafic Telnet et FTP provenant du 10.0.1.0 serait une solution, mais le trafic Telnet et FTP va franchir le tronçon réseau de **G0/1 de R1 jusqu'à G0/0 de R3** avant d'être refusé: gaspillage de ressources
- L'ACL sortante sur S0/0/0 de R1, puisque l'ACL étendue peut examiner les adresses source et de destination, seuls les paquets FTP et Telnet provenant de 10.0.1.0/24 seront refusés, mais l'inconvénient est que tout le trafic sortant de S0/0/0 est **traité** comme celui de 10.0.1.0
- L'ACL entrante sur G0/1, seuls les paquets du réseau 10.0.1.0/24 sont soumis à la liste de contrôle sur R1. (**meilleure solution**)

Position des ACL étendues

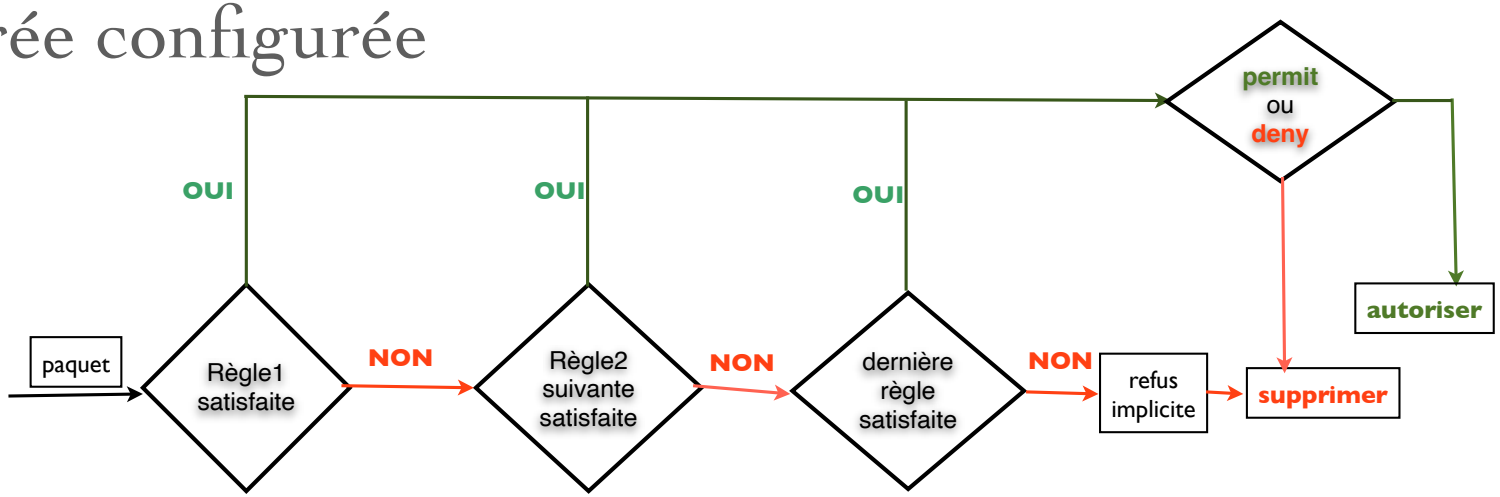
- L'administrateur du site A souhaite refuser le trafic Telnet et FTP provenant du réseau 10.0.2.0/24 vers le réseau 10.0.1.0/24 du site B



- L'ACL étendue sur R3 bloquant le trafic Telnet et FTP provenant du 10.0.2.0 serait une solution, mais l'administrateur **ne contrôle pas R3.**
- L'ACL entrante sur G0/1 de R1, seuls les paquets du réseau 10.0.2.0/24 sont soumis à la liste de contrôle sur R1, mais le trafic Telnet et FTP traversent le tronçon réseau de **S0/0/0 de R2 jusqu'à G0/1 de R1** avant d'être refusé
- L'ACL sortante sur S0/0/0 de R2, puisque l'ACL étendue peut examiner les adresses source et de destination, seuls les paquets FTP et Telnet provenant de 10.0.2.0/24 seront refusés, mais l'inconvénient est que tout le trafic sortant de S0/0/0 (exemple 10.0.3.0) est **traité par l'ACL** comme celui de 10.0.2.0. (**meilleure solution**)

Principes de configuration des ACL

- Les entrées de contrôle d'accès sont examinés dans l'ordre dans lequel elles apparaissent dans l'ACL.
- Si une correspondance est trouvée, le routeur traite le paquet en fonction de celle-ci et aucune autre ACL ne sera inspectée.
- Si aucune correspondance n'est trouvée, le trafic est refusé à cause de l'existence par défaut d'un refus implicite à la fin de toutes les ACL pour le trafic qui ne correspond à aucune entrée configurée



Configuration des ACL standards

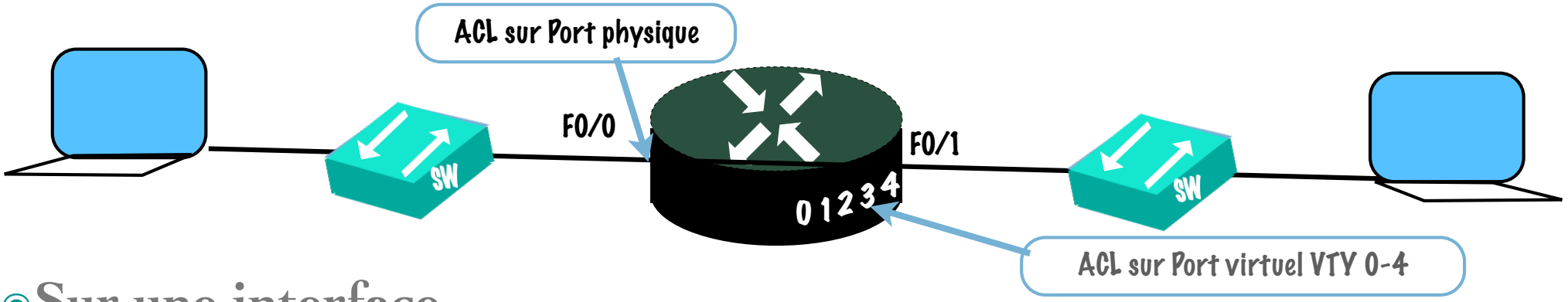
- La commande de configuration globale **`access-list`** définit une liste de contrôle d'accès standard, **`no access-list`** est utilisée pour supprimer la liste et **`show access-list`** pour vérifier
- **Définition**
- **`access-list numéro-de-la-liste {permit | deny} adresse-IP-source [masque-générique-source]`**
  - **`numéro-de-la-liste:`** entre 1 et 99 ou entre 1300 et 1399
  - **`deny:`** refuse si les règles sont vérifiées
  - **`permit:`** autorise si les règles sont vérifées
  - **`adresse-IP-source:`** numéro du réseau ou d'hôte(s) source(s)
  - **`masque-generique-source:`** masque générique appliqué à la source

Configuration des ACL standards

- Exemples
  - **Router1(config)#**access-list 1 permit 192.168.0.0 0.0.1.255 /*autorise les machines de 192.168.0.0 à 192.168.1.255*/
  - **Router1(config)#**access-list 50 permit 172.16.0.0 0.0.0.1 /*autorise les machines de 172.16.0.0 à 172.16.0.1*/
  - **Router1(config)#**access-list 99 permit 10.10.0.0 0.3.255.255 /*autorise les machines de 10.8.0.0 à 10.11.255.255*/
  - **Router1(config)#no** access-list 99 /*Supprime l'ACL 99*/
  - La commande **any** est utilisée pour indiquer n'importe quelles adresses (équivaut à la palge 0.0.0.0 à 255.255.255.255). La commande **host** remplace le masque 0.0.0.0.
  - **Router1(config)#**access-list 10 permit host 10.10.0.1 /*autorise la machine de 10.10.0.1*/

Application des ACL

- L'ACL une fois définie, doit être assignée à une interface ou un port



- Sur une interface

```
ip access-group <n°-liste> [in|out]
in|out: ACL est appliquée pour le trafic entrant ou sortant.
Router1(config)#interface FastEthernet0
Router1(config-if)#ip access-group 1 out /*applique l'ACL 1 à la sortie de l'interface*/
Router1(config)#interface FastEthernet1 /*applique l'ACL à l'interface FastEthernet1*/
Router1(config-if)#ip access-group 99 in /*applique l'ACL 99 à l'entrée de l'interface*/
```

- Sur un port

```
Router1(config)#line vty 0 4
Router1(config-line)#login
Router1(config-line)#password
Router1(config-line)#access-class  1 in
```

Modification des ACL

- Pour modifier une ACL il suffit de la supprimer et de la redéfinir. La commande `no ip access-group` sur l'interface, puis la commande globale `no access-list` suppriment l'ensemble de la liste.
  - **`Router1(config)#no access-list`** `numéro`
- **Exemple**
  - **`Router1(config)#no access-list`** `100` /*pour supprimer l'ACL de numéro 100*
  - **Router1(config)#**no access-list 1 /*Supprime l'ACL 1 si elle existe*/
  - **Router1(config)#**access-list 1 deny host 192.168.0.1 /*Refuse l'hote 192.168.0.1 mais aussi les autres hôtes*/
  - Rappelez-vous qu'il existe une instruction de refus global implicite **`access-list 1 deny 0.0.0.0 255.255.255.255.`**
  - Donc pour autoriser les autre hôtes il faut l'instruction:
  - **Router1(config)#**access-list 1 permit any

Ordre de définition des ACL

- **L'ordre de définition des entrées est important**
  - `GELT2(config)#interface FastEthernet0` /*sur l'interface FastEthernet0*/
  - `GELT2(config-if)#ip access-group 1 in` /*à l'entrée de FastEthernet0*/
  - `GELT2(config)#access-list 1 deny host 10.10.10.1` /*refuse les paquets du PC 10.10.10.1 à l'entrée de FastEthernet0 du routeur `GELT2`*/
  - `GELT2(config)#access-list 1 permit any`
- **Si l'ordre des entrées est inversé, comme suit**
  - `GELT2(config)#access-list 1 permit any`
  - `GELT2(config)#access-list 1 deny host 10.10.10.1`
  - La première autorise l'adresse source de chaque paquet. Par conséquent, l'ACL n'empêche pas l'hôte `10.10.10.1` d'accéder.

Configuration des ACL étendues

- Les ACL étendues peuvent filtrer en fonction: adresse source, adresse destination, protocole et numéro de port
- **Définition**
- access-list numéro-de-la-liste{deny | permit} protocole source (sur IP) **@IP-source** [masque-source] [opérateur] [numéro ou nom de port]] @IP-destination [masque-destination] [opérateur] [numéro ou nom de port] [established]
  - **`numéro-de-la-liste:`** entre 100 et 199 ou entre 2000 et 2699
  - **`deny:`** refuse si les règles sont vérifiées
  - **`permit:`** autorise si les règles sont vérifées
  - **`protocole:`** "**Protocole sur IP**" concerné: IP, TCP, ICMP, UDP, OSPF, EIGRP etc.
  - **`@IP-source:`** numéro du réseau ou d'hôte(s) source(s)
  - **`masque-source:`** masque générique appliqué à la source
  - **`masque-destination:`** masque générique appliqué à la destination
  - **`@IP-destination:`** numéro du réseau ou d'hôte(s) de destination
  - **`opérateur:`** eq=égal, neq= différent, gt =plus grand que, lt=moins grand que opérateur etc.
  - **`established:`** **(pour TCP seulement)** indique une connexion établie

Configuration des ACL étendues

- **Exemples**
  - **Router1(config)#**access-list 101 deny any host 172.16.4.1/* on refuse les paquets IP à destination du PC 172.16.4.1 et provenant de n'importe quelle source */
  - **Router1(config)#**access-list 101 permit tcp any gt 1023 host 192.168.1.1 eq 23 /*autorise les paquets TCP provenant d'un port > 1023 et à destination du port 23 de la machine 192.168.1.1*/
  - **Router1(config)#**access-list 101 deny tcp any host 10.1.1.1 eq http /*Refus des paquets TCP à destination du port 80 de la machine d'IP 10.1.1.1*/
- **Une ACL numérotée peut être composée de nombreuses règles.**
  - **Router1(config)#**access-list 100 deny udp host 212.16.23.6 host 10.23.4.6 eq tftp
  - **Router1(config)#**access-list 100 permit ip any any /* Refuser le PC 212.16.23.6 d'accéder au serveur TFTP 10.23.4.6 et autorise tout le trafic IP pour n'importe quelle source (any 1) vers n'importe quelle destination (any 2)*/
- Appliquer l'ACL à l'interface
  - **Router1(config-if)#**ip access-group 100 out /*applique l'ACL à la sortie de l'interface*/

Configuration des ACL nommés

- **Les ACL nommées** permettent de donner des noms à la place des numéros aux listes de contrôle d'accès standards et étendues
- **Définition**

```
Router1(config)#ip access-list {extended|standard} nom
Router1(config-std-nacl)#[permit ¡ deny]…… continuer avec la
définition de standard ou étendu….
Router1(config-if)#ip access-group nom [in ¡ out]
```

- **Exemple:**
  - bloquer tout le trafic, à l'exception de la connexion Telnet entre l'hôte 10.10.10.1 et l'hôte 172.16.1.1 et autoriser tout le trafic IP de n'importe quelle source vers n'importe quelle destination

```
Router1(config)#ip access-list extended nomACL
Router1(config-ext-nacl)#permit tcp host 10.10.10.1 host 172.16.1.1 eq
telnet/*règle 1*/
Router1(config-ext-nacl)#permit ip any any /*règle 2*/
Router1(config-if)#ip access-group nomACL in
Router1(config-ext-nacl) no permit ip any any/*supprimer la règle 2 de l'ACL nomACL,*/
```

Conseils pratiques pour la création d'ACL

- **Principes**
  - Refuser quelques flux réseau et autoriser le reste.
  - Autoriser quelques flux réseau et refuser le reste (plus sécurisé que le premier).
- Placer les ACL standards au plus près de la destination afin d'éviter de détruire un paquet trop top.
- Placer les ACL étendues au plus près possible de la source du paquet afin de le détruire le plus vite possible
- Placer la règle la plus spécifique en premier et les instructions les plus génériques en dernier (Par défaut, tout le trafic est interdit.)
- Avant de faire le moindre changement sur une ACL, désactiver la sur l'interface concerné (no ip access-group)
- Pour modifier l'ACL, il faut la supprimer puis la recréer